MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 077 · NOVEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

CASE IN POINT · ACCESS CONTROL

Wireless Access Under 3.1.16 and 3.1.17: Count the Radios First

NIST 800-171 3.1.16 and 3.1.17 put 10 SPRS points on wireless, none deferrable. One machine shop's floor plan, every radio on it, and a verdict for each.

BY **MAXINE** READING TIME · 7 MIN NIST-800-171 · WIRELESS · ACCESS-CONTROL · MANUFACTURING · SPRS

Ask a small manufacturer how its wireless is secured and the answer is a password. Ask how many wireless access points are inside the building and the answer is a pause, and the pause is the expensive one, because the first thing NIST SP 800-171 wants to know about wireless is not how it is protected but whether the program knows it is there.

The numbers make the case for caring. Requirement 3.1.16, authorize wireless access prior to allowing such connections, and 3.1.17, protect wireless access using authentication and encryption, each carry 5 points in the DoD Assessment Methodology. NIST SP 800-171A gives each two objectives, and every objective must be met for the requirement to score. None of the ten points can be deferred, because 32 CFR 170.21 bars any requirement worth more than 1 point from a Level 2 plan of action and milestones. Wireless has to be right on assessment day. The cheapest way to make it right is to have fewer radios to defend, and the way to get there is to put every radio in the building into one of three piles.

Consider a hypothetical precision machine shop of about forty people in one building: a front office, an engineering room where CAD stations open customer drawings marked CUI, a machine floor, an inspection room with a coordinate measuring machine, and a shipping dock. The shop has drawn its CUI boundary around a wired enclave of engineering workstations and the link that feeds programs to the controllers, the approach MacZine priced in enclave or whole network and toured in where the CNC machine sits. Then someone spends an afternoon with a passive WLAN scanner, the tool NIST SP 800-153 describes as recording what is transmitting in range while sending nothing itself, and marks up the floor plan.

Two ceiling access points in the office broadcast a staff network and a guest network. A consumer mesh extender, added last year so machine operators could pull job travelers onto tablets, broadcasts on the floor. The engineering printer advertises its own direct wireless mode. The inspection PC, cabled into the enclave, has a wireless card still joined to the staff network. The handheld scanners at shipping run on Wi-Fi. The supervisor's phone offers a hotspot. That marked-up plan is the evidence for objective 3.1.16[a], which asks only whether wireless access points are identified. Everything after it is a verdict, line by line, and the verdicts together answer 3.1.16[b]: whether each connection was authorized before it was allowed.

FIELD COPY
ISSUE Nº 077
NIST 800 171

10

SPRS POINTS ON WIRELESS, 5 FOR AUTHORIZING ACCESS UNDER 3.1.16 AND 5 FOR PROTECTING IT UNDER 3.1.17

4

NIST 800-171A OBJECTIVES ACROSS THE PAIR, AND ONE UNMET OBJECTIVE COSTS ITS REQUIREMENT THE FULL WEIGHT

2012

YEAR NIST PUBLISHED SP 800-153, ITS GUIDE TO SECURING WIRELESS LANS, STILL LISTED AS FINAL

The radios that leave the boundary

The guest network is the easy verdict, provided the separation is real. SP 800-153 recommends logically separated WLANs for guest and internal use, architected so guest traffic does not cross the organization's internal networks. The CMMC scoping rule at 32 CFR 170.19 asks the same of anything the shop wants to call out of scope: an asset that cannot process, store or transmit CUI and is physically or logically separated from the assets that do. A guest network on its own VLAN, routed to the internet and nowhere else, with a firewall rule that says so, meets that test. A guest network that differs from the staff network only by its password does not, and an assessor reading the boundary diagram will notice.

The printer is a harder lesson. It prints CUI drawings, so it sits inside the boundary, and its direct wireless mode is an access point inside the boundary that nobody authorized. The verdict is off, in the device configuration, with a record of the setting. The supervisor's hotspot gets a written prohibition for devices inside the CUI area and the next scan as the check that the rule holds. Each radio in this pile costs a configuration change and a sentence in the security plan, which is why the pile should be as large as the work allows.

The radios that stay, and what they owe

The mesh extender is the line that decides the shop's score. If the job travelers on those tablets carry CUI drawings, the extender transmits CUI and it is inside the boundary, wireless and all. The shop can move the tablets to a wired dock and switch the extender off, or it can replace a consumer device with a managed access point that meets both objectives of 3.1.17 and enforces the authorization 3.1.16 asks for at the moment of connection.

Encryption, objective 3.1.17[a], is the half programs expect. Where cryptography protects CUI on the radio link, requirement 3.13.11 also applies, and the methodology subtracts 5 points when encryption is absent and 3 when it is present but not FIPS-validated. That 3-point state is the single exception 170.21 allows onto a POA&M, so a strong but unvalidated access point is a recoverable problem in a way a missing 3.1.17 is not.

◆ THE GUIDE THE REQUIREMENT STILL CITES

The discussion under 3.1.16 in NIST SP 800-171 Rev 2 points readers to SP 800-97, NIST's guide to IEEE 802.11i wireless networks. NIST withdrew SP 800-97 on December 31, 2025, calling it technologically outdated and referring readers to the IEEE 802.11 standards. DoD still scores Rev 2, so the requirement stands while the guidance behind it has gone to the archive.

Authentication, objective 3.1.17[b], is where the shared password deserves scrutiny. The Rev 2 discussion says organizations authenticate individuals and devices, and SP 800-97, the guide cited in the Rev 2 discussion of 3.1.16, told organizations to choose IEEE 802.1X and EAP "instead of using PSKs," citing both the administrative burden and the risk. A pre-shared key known to three operators, two former employees and the controller vendor's field technician identifies none of them. WPA3-Personal hardens a shared password against guessing, by the Wi-Fi Alliance's own account, but it remains a shared password. WPA2-Enterprise or WPA3-Enterprise ties each connection to an account in the directory the enclave already runs, and the authentication server's log names who connected and when. The requirement text never says Enterprise, and a well-managed key may satisfy an assessor; that is a judgment, not a rule. It is also the judgment the objective invites, and the Enterprise answer is the one that arrives with its own evidence.

The shipping scanners show why the piles matter. If the labels they read carry no CUI, the scanners belong on a separate network outside the boundary, and the shop has moved a fleet of small networked devices, the sort the Rev 2 discussion flags for special attention, off its assessment.

A program can encrypt only the networks it knows about. The scan is how it learns about the rest.

The radio nobody switched on

The inspection PC is the finding that justifies the afternoon. SP 800-153 calls a device on a wired network and a WLAN at once dual connected, and warns that an attacker who gains wireless access to it can use it to reach the wired network behind it. Here that means a path from the staff network into the enclave, through a machine that was cabled in correctly and audited as a wired asset. The guide's remedy is to disable network interfaces that are not authorized and configure the device so the user cannot turn them back on.

The same guide's warning about rogue access points, devices dressed up as part of the organization's network that can open "a backdoor into the wired network," is why the scan belongs on a schedule rather than in a memory. SP 800-153 recommends a technical WLAN assessment at least annually and periodic assessments at least quarterly unless continuous monitoring already collects what they would. The mesh extender arrived between scans once; the next unauthorized radio will too.

The 800-171A examine lists for both requirements read like a description of this file: wireless access authorizations, procedures for wireless implementation and usage, the security plan, system design documentation, configuration settings, audit logs. The interview goes to whoever manages wireless connections. The test goes to the mechanisms themselves, which can mean an assessor checking that the guest network really cannot reach the enclave.

What the shop ends with is its floor plan, annotated: every radio, its verdict, the setting or log behind the verdict, and the date of the last scan. That document matters more here than it would for most controls, because the guidance under the requirement is aging out from under it. SP 800-97, the wireless guide the Rev 2 discussion still cites, is now an archived publication, and no NIST document a small shop can point to will name the exact wireless configuration that suffices. The requirement stays. What an assessor measures the shop against is the authorization list the shop wrote for itself, and the radios it found before anyone else did. ◆